

RESOLUTION ON THE ARCHIVING OF PROCEEDINGS

From the proceedings carried out by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: On July 16, 2023, a complaint was filed with registration number REGAGE23e00048055912 before the Spanish Agency for Data Protection against PIZZERÍAS CAMBALACHE, S.L. with NIF B15203979 (hereinafter, CAMBALACHE). The reasons for the complaint are as follows: The complainant alleges that, after placing an order on 12/05/2023 at ***EMAIL.1, the only available payment method was "bank transfer," which displayed a bank account number and a holder that appeared unrelated to the company. After making the payment via bank transfer, the complainant mistakenly transferred an amount significantly higher than that of their order. Upon attempting to claim a refund, the complainant states that the company "disclaims any claims or assumption of responsibility for the security breach on its own website and even disclaims any breach or security failure, which is evident since the company has on its official website a bank account number and a holder completely unrelated to its commercial activity."

The complainant provides two screenshots reflecting the order confirmation email indicating that the payment method was a bank transfer.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), this complaint was forwarded to CAMBALACHE for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the provisions of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was acknowledged on September 19, 2023, as evidenced by the acknowledgment of receipt in the file.

THIRD: On October 16, 2023, in accordance with Article 65 of the LOPDGDD, the complaint was admitted for processing.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

FOURTH: CAMBALACHE responded to the AEPD's request for information on October 20, 2023, indicating that on 12/05/2023, a bank transfer was detected for one of the orders as a pending payment, alerting the person in charge of managing the website, who confirmed that an external attack had occurred, disabling the usual payment methods, which were replaced by "bank transfer" to the account in Belgium: IBAN: BE00 0000 0000 0000 BIC/SWIFT: XXXXXXXXXXXX, whose holder is A.A.A.

Upon reviewing the server data and the website logs of the SumUp module configuration, it was confirmed that the hacker accessed the website's administration panel on 12/05/2023 between 16:12 and 16:50, adding the bank transfer details at 16:50. The logs do not indicate that there was access to the customer database, nor that there was any data exfiltration. Following the analysis conducted by the provider, no evidence of the cause of the incident was found, and the credentials were reset, and access privileges were reviewed, thus resolving the incident.

CAMBALACHE states that the incident only affected two individuals, and as a result, the hacker obtained the identifying data of each sender, as well as their bank account number and the amounts of money transferred from their accounts.

To resolve the incident, access credentials to the website administration were reviewed, permissions were checked, and payment processes were monitored in the following days to ensure the proper functioning of the purchasing process. To minimize the impact on the affected individuals, they were

provided with the necessary explanation, and the amount paid unlawfully was refunded. Finally, CAMBALACHE also reported the incident to the National Police.

Regarding the security measures prior to the incident, CAMBALACHE provided the AEPD with the complete record of processing activities of the "Customer Management" module, which includes digital assets for both the website and the mobile app. Security is outsourced to the technology company Hacce Soluciones TIC, S.L., which is recognized for its reliability in the sector.

CAMBALACHE does not conduct impact assessments (EIPD or PIA) because the type of processing does not require it, as it involves e-commerce for the purchase of food for pickup or home delivery, without processing sensitive data or using disruptive technologies, thus not falling within the provisions of Article 35 of the GDPR or the list published by the AEPD in this regard.

Regarding future measures, CAMBALACHE provided the report from its data processing manager, Hacce Soluciones TIC, S.L., which proposes, in summary, greater proactivity in implementing the latest measures from the manufacturer and developer of the web technology, as well as the most recent solutions in the hardware field, especially those related to security and cybersecurity. It also plans to scan the purchasing processes for products more frequently to verify their security.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/9

CAMBALACHE, relying on the "Gap Advisor" tool from the AEPD's corporate website, considers that it is not necessary to notify the AEPD of the security breach before the lapse of 72 hours, as it does not pose a risk to the rights and freedoms of individuals.

LEGAL GROUNDS

I

Competence

In accordance with the functions conferred to each supervisory authority by Article 57.1 a), f), and h) of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR) and as provided in Articles 47 and 48.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to resolve these investigative actions.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

Definitions from Article 4 of the GDPR

"1) 'personal data': any information relating to an identified or identifiable natural person ('the data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more specific elements of the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person;

2) 'processing': any operation or set of operations performed on personal data or sets of personal data, whether or not by automated means, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination, or otherwise making available, alignment or combination, restriction, erasure, or destruction;

7) 'data controller' or 'controller': the natural or legal person, public authority, service, or other body which, alone or jointly with others, determines the purposes and means of the processing; where the purposes and means of processing are determined by Union or Member State law, the controller or the specific criteria for its designation may be provided for by Union or Member State law;

8) 'processor' or 'processor': the natural or legal person, public authority, service, or other body which

processes personal data on behalf of the controller;

12) 'personal data breach': a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data transmitted, stored, or otherwise processed;"

In accordance with paragraphs 1 and 2 of Article 4 of the GDPR, CAMBALACHE through its corporate website, ***EMAIL.1, processes personal data of its clients, mainly names, surnames, job details, and, where applicable, delivery address for the ordered food.

In accordance with the definition in paragraph 7 of Article 4 of the GDPR, CAMBALACHE is the data controller as it is the legal entity that determines the purposes and means of the indicated processing. In this case, since both the management of the website and security are outsourced, we have two external processors on behalf of the controller in accordance with the definition in paragraph 8 of Article 4 of the GDPR, namely a natural person, D. B.B.B., responsible for the IT systems in general, and a legal entity specifically contracted for IT security, Hacce Soluciones TIC, S.L.

Finally, in accordance with the definition in paragraph 12 of Article 4 of the GDPR, a personal data breach occurred on CAMBALACHE's website on 12/05/2023 between 16:10 and 16:50 when a hacker impersonated the normal payment methods for orders and unlawfully accessed the personal data of 2 CAMBALACHE clients when they used its corporate website to pay for an order.

III

Principles Relating to Processing

Confidentiality

Letter f) of Article 5.1 of the GDPR regulates the principles of integrity and confidentiality:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by applying appropriate technical or organizational measures ('integrity and confidentiality')."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/9

In accordance with this provision, CAMBALACHE, as the data controller, has the obligation to ensure the confidentiality of personal data through adequate security, including protection against unauthorized or unlawful processing.

In this case, the hacker has replaced the payment section of the corporate website with another destination account with the intent to defraud CAMBALACHE's customers, creating the appearance that they are making a purchase with the restaurant itself. The acquisition of data through this phishing method is an additional consequence of this action.

This means that the loss of confidentiality does not refer to the personal data subject to processing carried out by CAMBALACHE.

IV

Security Measures

However, as the data controller, it must also comply with the provisions of Article 32.1 of the GDPR, which stipulates the following regarding the security of processing (applicable parts are underlined):

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying probabilities and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;

b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;

c) the ability to restore the availability and access to personal data quickly in the event of a physical or

technical incident;

d) a process for regularly verifying, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

CAMBALACHE and its processors must implement appropriate technical and organizational measures to ensure a level of security against the risk of phishing of customer data accessing its corporate website, ensuring the confidentiality that the data collected through its website is effectively collected by CAMBALACHE and not by unauthorized third parties. The measures will be adopted based on the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing.

V

Obligation to Notify Personal Data Breaches to the AEPD

Precisely to ensure the adoption of appropriate measures, Article 33 of the GDPR establishes the general obligation to notify personal data breaches to the AEPD, in its capacity as the supervisory authority, stating the following:

“1. In the event of a personal data security breach, the data controller shall notify the competent supervisory authority in accordance with Article 55 without undue delay and, where feasible, no later than 72 hours after becoming aware of it, unless it is unlikely that the personal data breach will result in a risk to the rights and freedoms of natural persons. If the notification to the supervisory authority does not take place within 72 hours, it shall be accompanied by the reasons for the delay.

2. The processor shall notify the controller without undue delay of any personal data breaches of which it becomes aware.

3. The notification referred to in paragraph 1 shall, at a minimum:

a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of data subjects affected, and the categories and approximate number of personal data records affected;

b) communicate the name and contact details of the data protection officer or another contact point where more information can be obtained;

c) describe the possible consequences of the personal data breach;

d) describe the measures taken or proposed by the controller to remedy the personal data breach, including, where appropriate, the measures taken to mitigate any possible negative effects.

4. If it is not possible to provide the information simultaneously, and to the extent that it is not possible, the information shall be provided gradually without undue delay.

5. The controller shall document any personal data breaches, including the facts relating to the breach, its effects, and the remedial measures taken. This documentation shall enable the supervisory authority to verify compliance with the provisions of this article.”

As CAMBALACHE did not notify the AEPD of the personal data breach, and the AEPD became aware of it through a complaint from an affected individual, the AEPD requested information from CAMBALACHE regarding its actions concerning the facts subject to the complaint, following the requirements of Article 33 that apply to the case.

- Obligation to notify the breach to the AEPD (Article 33.1): CAMBALACHE, relying on the "Breach Advisor" tool from the AEPD's corporate website, considers that it is not necessary to notify the security breach to the AEPD.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/9

AEPD before the lapse of 72 hours, as it does not pose a risk to the rights and freedoms of individuals.

□

Description of the nature of the breach (33.3 section a): On 12/05/2023 at 20:50, a report was made to the IT manager from a Pizzerías Cambalache location regarding an order with "Pending bank transfer payment;" who in turn informed the security company at 20:58. At 21:07, it was confirmed that an external attack had occurred, consisting of the impersonation of the usual payment methods by "bank

transfer" to the account in Belgium: IBAN: BE00 0000 0000 0000 BIC/SWIFT: XXXXXXXXXXXX whose holder is A.A.A. At that same moment, it was decided to remove the part of the configuration added by the attacker and revert the page to its state prior to the attack, thus restoring normal operation. On 12/05/2023 between 16:12 and 16:50, an external attack occurred on the corporate website of CAMBALECHE. There is no record in the logs of any access to the customer database, nor of any data exfiltration.

□

Categories and approximate number of affected data subjects of affected personal data records, and the categories and approximate number (article 33.3 section a in fine): identifying data of two (2) individuals, their bank account number, and the amounts of money transferred from their accounts.

□

Description of the possible consequences of the breach: economic harm due to the amounts of money transferred along with the phishing of their identifying data and bank account number, with the potential future misuse of this information.

□

Measures adopted or proposed by the data controller to remedy the breach (article 33.3 c) start): CAMBALACHE resolved the incident by resetting the access credentials to the administration of the website, and the access permissions and privileges were reviewed, along with monitoring the payment processes in the following days, with the aim of verifying the proper functioning of the purchasing process.

□

Mitigating measures for possible negative effects to minimize their impact on the affected individuals (article 33.3 c in fine): it states that the affected individuals received the necessary explanation from CAMBALACHE and were reimbursed the amount transferred unlawfully, although only documentation of an email to the claimant informing them of the incident with the bank account is provided. Finally, CAMBALACHE also reported the events to the National Police.

□

Obligation of the data controller to document and make available to the AEPD the facts related to the breach, its effects, and the corrective measures adopted (article 33.5): It provides the incident report from the security manager, as well as the report to the National Police. Regarding the security measures prior to the incident, CAMBALACHE provides the AEPD with the complete record of processing activities from the "Customer Management" module that includes the digital assets, both for the website and for the mobile app;

As for future measures, the report from the security manager of CAMBALACHE proposes, in summary, greater proactivity in implementing the latest measures from the manufacturer and developer of the web technology, as well as the most recent solutions in the hardware field, especially those related to security and cybersecurity. It also plans to scan the purchasing processes of products more frequently to verify their security.

VI

Conclusion

The cyber attack is directed against the corporate website of CAMBALACHE, the attacker has modified its content and replaced the payment section of the corporate website with a destination bank account that has nothing to do with the company. The attacker interposes themselves between CAMBALACHE and its customers with the intent to defraud the latter and also obtains their identifying data and bank account number through phishing.

In light of the facts presented, it is concluded that there is no evidence of a violation of the GDPR. Therefore, based on the information indicated in the previous paragraphs, no evidence has been found that supports the existence of a violation within the jurisdiction of the Spanish Agency for Data Protection.

All of this is without prejudice to any possible subsequent actions that this Agency may carry out, applying the investigative and corrective powers it holds.

In accordance with what is stated, by the Director of the Spanish Agency for Data Protection, IT IS AGREED:

FIRST: TO ARCHIVE the present proceedings.

SECOND: TO NOTIFY this resolution to PIZZERÍAS CAMBALACHE, S.L. and to the claimant.

In accordance with the provisions of article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative process as provided by art. 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, and in accordance with the provisions of arts. 112 and 123 of the aforementioned Law 39/2015, of October 1, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/9

following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within a period of two months starting from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

940-301023

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es